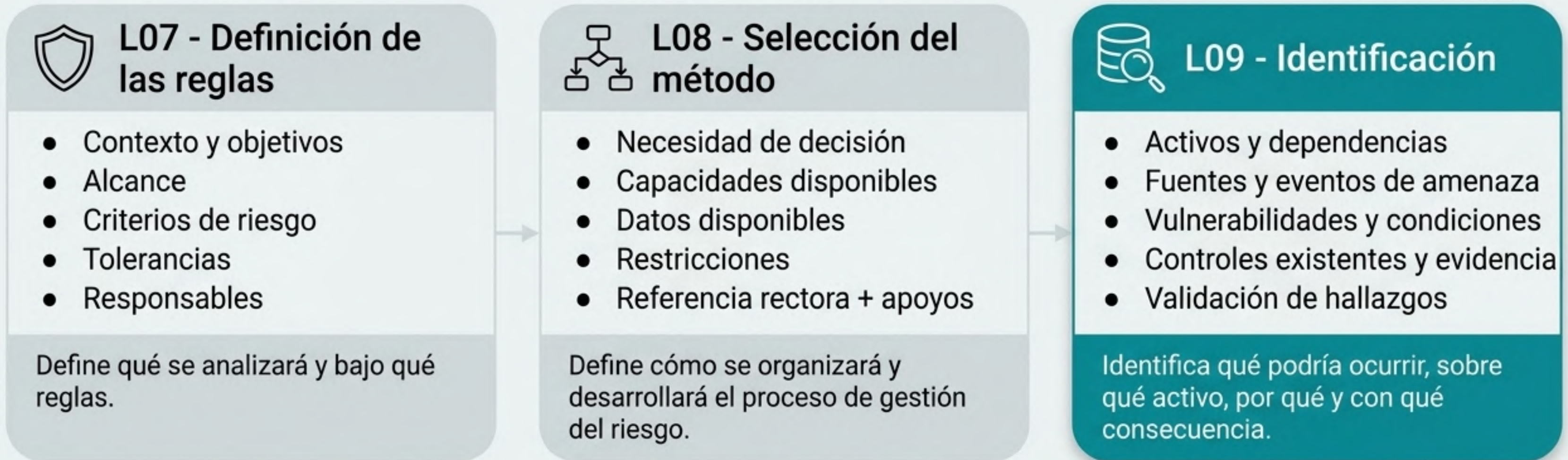


Identificación de riesgos: activos, amenazas, vulnerabilidades y validación

Lección 09 - INF44 Gestión de la Seguridad



Contexto y criterios → Método → **Identificación**



En esta etapa todavía **NO** se asignan probabilidad, impacto, criticidad ni prioridad.

Fase actual: identificación y validación

Dónde estamos: El paso antes de valorar

El Propósito



Inventario de
Activos



Pregunta clave:
¿Qué podría ocurrir,
sobre qué y por qué?



Registro Inicial
de Escenarios

Pregunta clave:

¿Qué podría ocurrir, sobre
qué y por qué?

Entregables:

Inventario de activos +
Registro inicial de escenarios.



**! Regla de Oro: Todavía
NO se asignan niveles.**

En esta etapa no se calcula
probabilidad, impacto, criticidad ni
prioridad.

Nota del Analista:

Intentar puntuar antes de describir
exhaustivamente convierte el análisis
en simples suposiciones. Primero se
describe el escenario; la valoración
viene después.

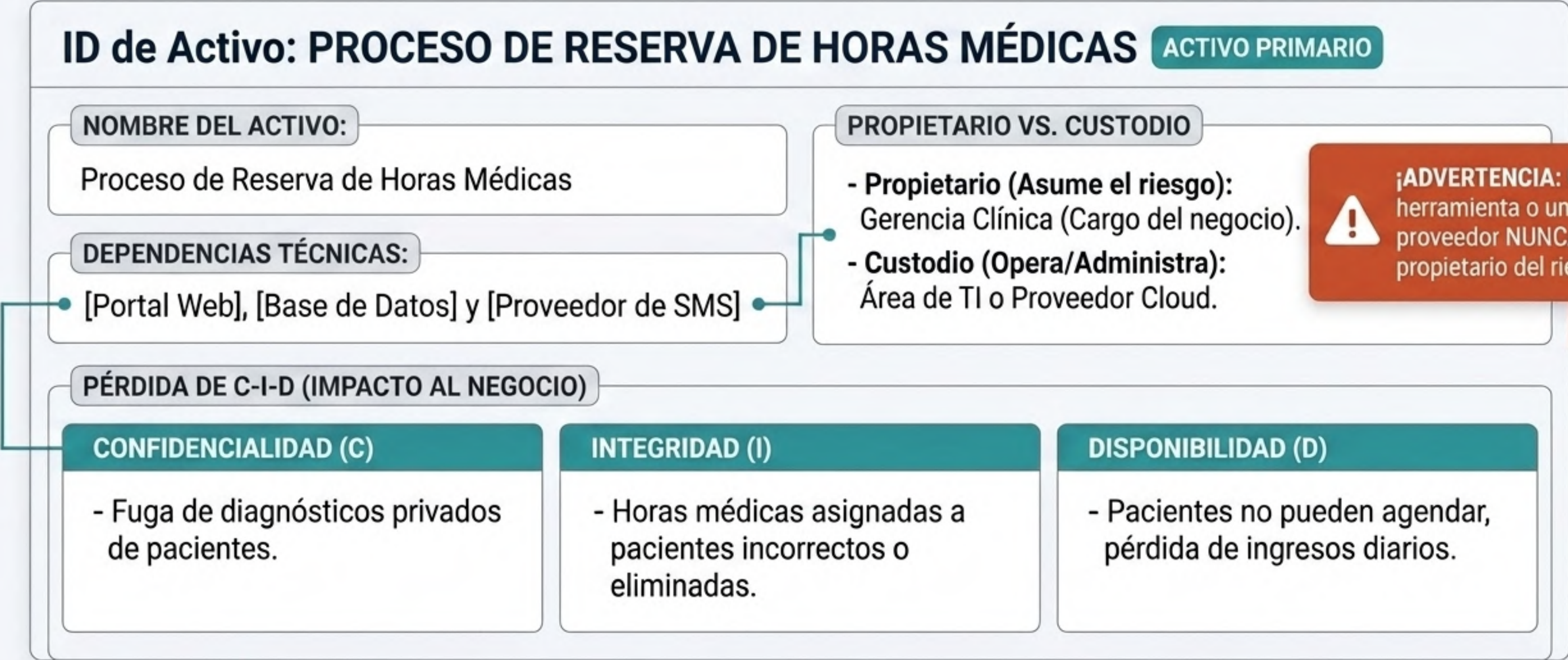
Activos: ¿Qué estamos protegiendo?

Un activo es algo valioso que, si se afecta, compromete un objetivo del negocio.



Idea clave: El valor de un activo de soporte deriva del proceso o la información que sostiene. Un servidor vale lo que vale el proceso o la información que depende de él.

Anatomía del Inventario de Activos





¡ADVERTENCIA: Una herramienta o un proveedor NUNCA es el propietario del riesgo!

Errores de clasificación: Qué NO es un activo

CONCEPTO INCORRECTO

✗ Phishing

✗ Contraseñas débiles

✗ Ley de Protección de Datos

✗ Firewall

✗ Hackeo

CORRECCIÓN Y CLASIFICACIÓN

✓ Es un **Evento de amenaza** (una técnica), no un activo.
[EVENTO DE AMENAZA]

✓ Es una **Vulnerabilidad** (una debilidad). [VULNERABILIDAD]

✓ Es un **Requisito/Obligación** que define consecuencias.
[REQUISITO/OBLIGACIÓN]

✓ Es un **Activo de soporte** (si es un equipo físico) o un **Control** (si se evalúa su función protectora). [CONTROL]

✓ Palabra vaga. Debe descomponerse en fuente, evento, vulnerabilidad y activo. No se registra así. [PALABRA VAGA]

Amenazas: Quién o qué, y qué hace



Fuente: ¿Quién o qué lo causa?

Ej: Grupo criminal, empleado, hardware.

Evento: ¿Qué ocurre?

Ej: Usa credenciales robadas, envía correo equivocado.



Adversaria

Intención maliciosa. Delincuentes, competidores. (Usan tácticas MITRE ATT&CK).

Accidental

Sin intención. Empleados distraídos, errores humanos.

Estructural

Fallas de tecnología o servicios. Caída de proveedor, disco dañado.

Ambiental

Naturaleza o infraestructura física. Sismo, corte eléctrico.



No todo riesgo tiene un atacante. Una caída de un proveedor crítico (Estructural) puede costar más que un ciberataque.

La brecha: Vulnerabilidades vs. Condiciones



Vulnerabilidad (Debilidad aprovechable)

Técnica:

Software sin parche,
puerto de red
expuesto.

De proceso:

Cambios en sistemas
de producción sin
revisión previa.

De personas:

Falta total de
inducción en
seguridad.

Contractual:

Ausencia de un SLA
(Acuerdo de Nivel de
Servicio) definido
con el proveedor.



Condición Predisponente (Facilitador)

Características del entorno que hacen más probable el éxito de un evento, aunque no sean errores.

Ejemplos:

- Dependencia de un único proveedor de internet; concentrar el 80% de la operación anual en un solo mes del año; personal disperso trabajando en terreno.

Controles: Diferenciar Existe de Funciona

Un control documentado no cuenta para mitigar el riesgo; solo es válido si hay **evidencia comprobable** de su operación.



Si no hay prueba, en el registro se anota estrictamente: **Sin evidencia de operación.**

Mesa de trabajo del analista

El Escenario de Riesgo: Ensamblando las piezas



Taller de redacción: De idea vaga a escenario completo

La **consecuencia** debe expresarse en términos del impacto al negocio, sus objetivos o requisitos. No basta con escribir «el servidor se cae».

⚠ Antes

Débil: Riesgo de phishing alto.

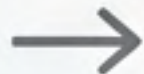


✓ Después

Completo: [Atacante externo] engaña al personal mediante [correos falsos], aprovechando [falta de capacitación], afectando el [proceso de pagos], lo que provoca [desvío de fondos y pérdida financiera].

⚠ Antes

Débil: El proveedor de la nube es un riesgo.



✓ Después

Completo: [Proveedor de nube] sufre [corte de energía] bajo un [contrato sin garantías de continuidad] afectando el [CRM de ventas], impidiendo [procesar ingresos por 2 días].

Mesa de trabajo del analista

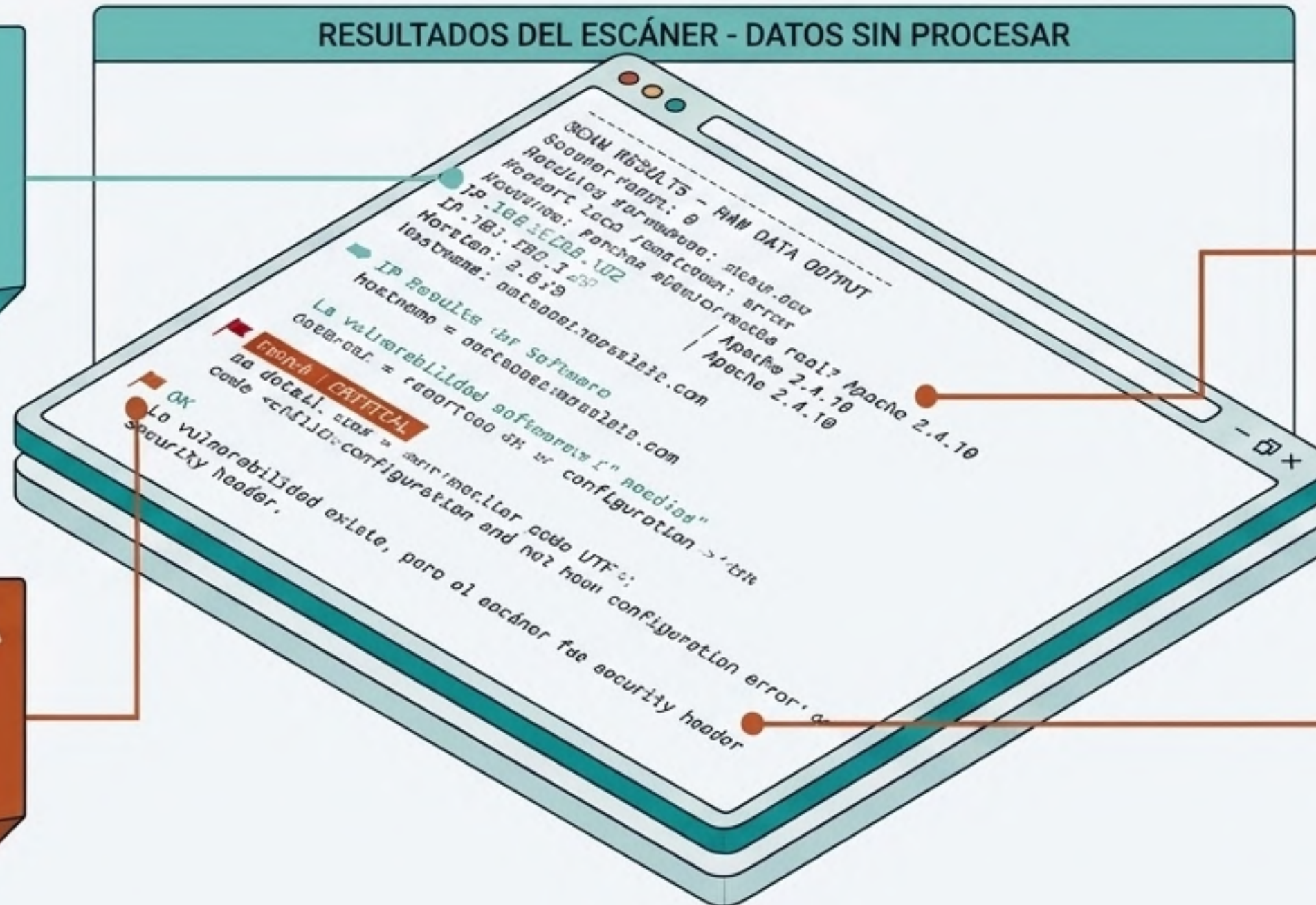
El Escáner: Un hallazgo es un dato, no una condena absoluta

Un reporte técnico compara lo que observa con una base de firmas. No representa un riesgo real por sí solo.

Alcance:

¿Este activo realmente pertenece a nuestro inventario validado?

RESULTADOS DEL ESCÁNER - DATOS SIN PROCESAR



Método de Detección:

¿Lo detectó leyendo el número de versión o ejecutó una prueba real? (Atención a los Backports: parches aplicados a versiones antiguas que el escáner no nota).

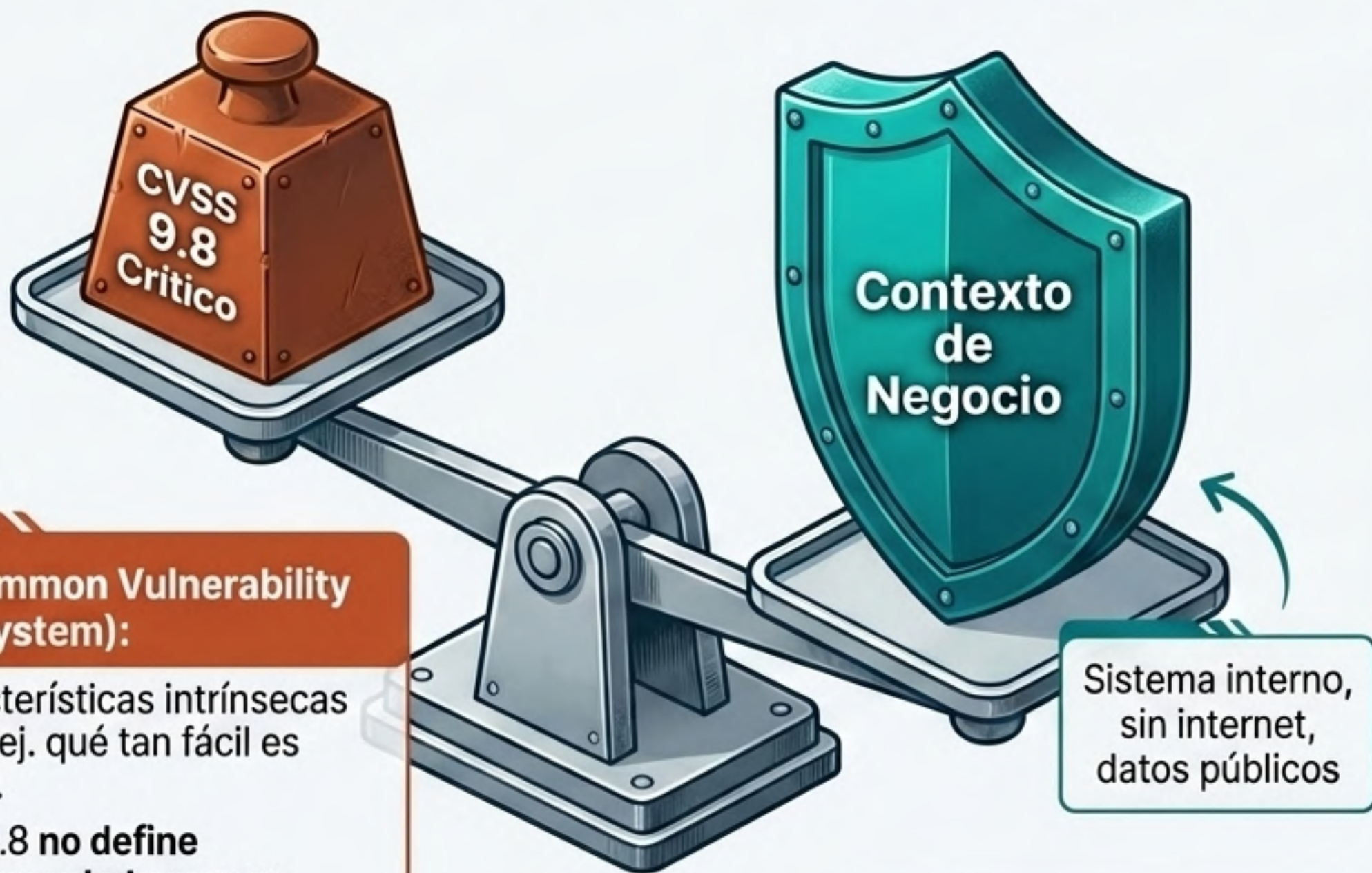
Falsos Positivos:

La vulnerabilidad es reportada, pero hay evidencia de que no existe.

Falsos Negativos:

La vulnerabilidad existe, pero el escáner fue incapaz de verla.

Severidad Técnica ≠ Riesgo de Negocio



CVSS (Common Vulnerability Scoring System):

Mide características intrínsecas de la falla (ej. qué tan fácil es explotarla).

Un CVSS 9.8 **no define automáticamente tu mayor riesgo organizacional**. Copiar este número a la matriz de riesgos es un **error**.

Herramientas de Contexto (Complementos, no sustitutos):

- **KEV (CISA): Catálogo de vulnerabilidades** con evidencia de explotación activa en el mundo real.
- **EPSS (FIRST): Modelo predictivo**; estima la probabilidad de que una falla sea explotada en los próximos 30 días.

Sistema interno,
sin internet,
datos públicos

KEV y EPSS aportan contexto sobre explotación y priorización técnica, pero **no sustituyen la valoración del riesgo** de la organización.

Validación No Destructiva: Confirmar sin romper



Examinar

(Método preferido en esta etapa)



Revisar configuraciones exportadas, logs, inventarios, contratos. Comparar hashes de archivos.

Confirmar configuraciones sin alterar el estado del sistema.

Entrevistar

(Método preferido en esta etapa)



Preguntar al custodio o administrador técnico. Solicitar al proveedor confirmaciones escritas sobre la instalación de un parche.

Recolectar evidencia y confirmaciones verbales y escritas.

Probar (⚠ CUIDADO)

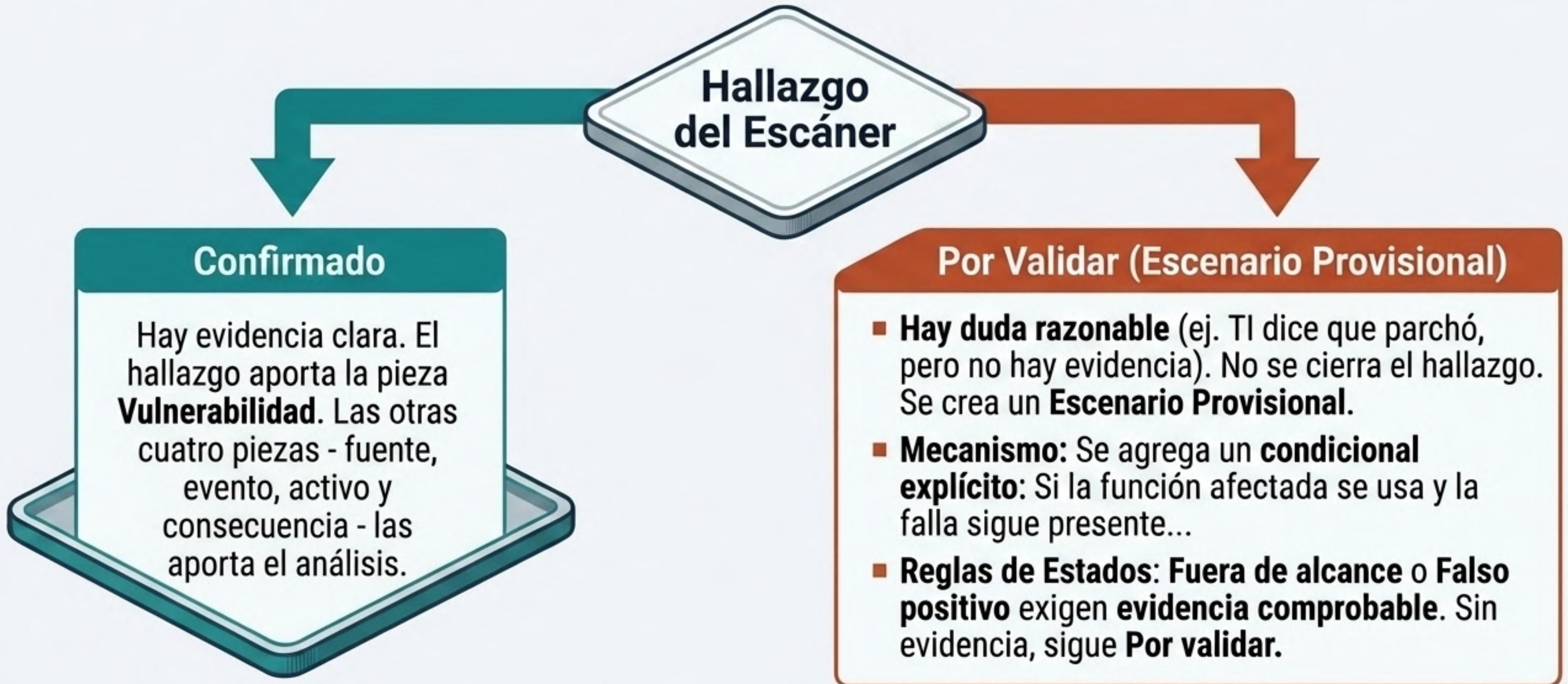
PRUEBA ACTIVA

Ejecutar pruebas técnicas controladas o escaneos activos autorizados.

Regla: Solo con autorización explícita, plan y ventana de mantenimiento. Intentar explotar una vulnerabilidad solo para comprobarla puede interrumpir el servicio y, sin autorización, generar consecuencias legales.

La duda en gestión de riesgos se resuelve con documentación y evidencia, no con ataques ciegos.

Del Hallazgo al Registro: Manejo de la Incertidumbre



Mesa de trabajo del analista

Síntesis y Checklist de Preparación

- ☐ Alcance respetado estrictamente.
- ☐ Los activos cuentan con **un propietario responsable** dentro de la organización, no una herramienta ni un proveedor.
- ☐ Escenarios redactados con la **fórmula de 5 piezas**.
- ☐ **Consecuencias** expresadas en **lenguaje** de negocio.
- ☐ Controles cuentan con **evidencia comprobable** (o se declaran sin ella).
- ☐ Ningún escenario tiene puntaje ni nivel de riesgo aún.

Autoevaluación rápida:

1. ¿Por qué el proveedor de tu ERP en la nube NO es el propietario del riesgo de esa información?

3. ¿Por qué no puedes descartar un hallazgo del escáner solo porque TI dice que ya lo arregló?

2. Menciona un evento de amenaza cuyo origen no sea un ataque humano.

Con estas herramientas, estás listo para identificar y documentar riesgos antes de valorarlos.